



Частное учреждение профессионального образования

«Высшая школа предпринимательства»

(ЧУПО «ВШП»)

ДИПЛОМНЫЙ ПРОЕКТ

по основной образовательной программе

среднего профессионального образования по специальности

09.02.07 «Информационные системы и программирование» на тему:

Разработка и внедрение сервиса двухфакторной аутентификации для
доменной инфраструктуры на базе Active Directory с использованием
программного обеспечения MultiOTP

Выполнил студент

(подпись)

Радионов Дмитрий Григорьевич

(фамилия, имя, отчество)

Руководитель

(подпись)

Бакланов Александр Александрович

(ученая степень, фамилия, имя, отчество)

Рецензент

(подпись)

(ученая степень, фамилия, имя, отчество)

(должность)

(место работы)

Председатель ГЭК

(подпись)

(ученая степень, фамилия, имя, отчество)

Оценка

(прописью)

Дата защиты:

20__г.

Оглавление

Оглавление	2
ОПРЕДЕЛЕНИЕ, ОБОЗНАЧЕНИЕ И СОКРАЩЕНИЕ.	4
ВВЕДЕНИЕ	5
Глава 1. Теоретические основы обеспечения безопасности доменной инфраструктуры и применения двухфакторной аутентификации	9
1.1 Анализ доменной инфраструктуры как объекта защиты	9
1.1.1 Назначение и архитектура службы каталогов AD	9
1.1.2 Значение AD в обеспечении безопасности организации	10
1.1.3 Обоснование необходимости усиления защиты учетных записей	11
1.2 Анализ угроз информационной безопасности доменной инфраструктуры	12
1.2.1 Классификация актуальных угроз для доменной среды	12
1.2.1.1 Модель нарушителя и оценка рисков	14
1.2.2 Технические атаки на механизмы аутентификации	14
1.2.3 Недостатки однофакторной парольной аутентификации	16
1.3 Теоретические основы двухфакторной аутентификации	18
1.3.1 Понятие и принципы многофакторной аутентификации	18
1.3.2 Протокол TOTP как механизм реализации 2FA	19
1.3.3 Особенности внедрения 2FA в доменной инфраструктуре	22
1.4 Сравнительный анализ решений 2FA для доменной среды	26
1.4.1 Критерии сравнения программных продуктов	26
1.4.2 Обзор существующих решений	27
1.4.3 Сравнительная таблица решений	29
1.4.4 Обоснование выбора программного комплекса MultiOTP	30

Выводы по главе 1	31
Глава 2. Разработка и внедрение сервиса 2FA на базе MultiOTP	33
2.1 Проектирование архитектуры сервиса 2FA	33
2.1.1 Анализ существующей инфраструктуры	33
2.1.2 Общая схема взаимодействия компонентов	34
2.1.3 Логика работы системы	35
2.1.4 Обеспечение отказоустойчивости сервиса	37
2.1.5 Выводы	37
2.2 Реализация серверной части на базе MultiOTP	38
2.2.1 Подготовка инфраструктуры	38
2.2.2 Установка MultiOTP	39
2.2.3 Файл конфигурации multiotp.ini	42
2.2.4 Интеграция с AD через LDAP	43
2.2.5 Настройка Credential Provider	44
2.2.6 Выводы	45
2.3 Настройка клиентской части и регистрация пользователей	46
2.3.1 Синхронизация пользователей из AD	46
2.3.2 Процесс регистрации пользователя	47
2.3.3 Инструкция для пользователя	49
2.3.4 Процедура восстановления доступа при утере телефона	49
2.4 Тестирование разработанного решения	50
2.4.1 Методика тестирования	50
2.4.2 Результаты тестирования	51
2.4.3 Сводная таблица результатов	52
2.4.4 Оценка производительности и масштабируемости	53

Выводы по главе 2	58
ЗАКЛЮЧЕНИЕ	59
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ	64
Приложения А	67

ОПРЕДЕЛЕНИЕ, ОБОЗНАЧЕНИЕ И СОКРАЩЕНИЕ.

В настоящем текстовом документе применяются следующие определения, обозначения и сокращения:

1. 2FA - Two Factor Authentication - двухфакторная аутентификация.
2. AD - Active Directory - служба каталогов.
3. GPO - Group Policy Object - объект групповой политики.
4. HMAC - hash-based message authentication code - код проверки подлинности сообщений, использующий односторонние хеш функции в криптографии
5. HOTP - HMAC based One Time Password - одноразовый пароль на основе HMAC.
6. LDAP - Lightweight Directory Access Protocol - облегченный протокол доступа к каталогам.
7. MFA - Multi Factor Authentication - многофакторная аутентификация.
8. NTLM - NT LAN Manager - менеджер сетевой аутентификации Windows NT.
9. OTP - One-Time Password - одноразовый пароль.
10. RADIUS - Remote Authentication Dial n User Service - служба удаленной аутентификации пользователей по коммутируемым линиям.
11. RBAC - Role-Based Access Control - управление доступом на основе ролей.
12. RDP - Remote Desktop Protocol - протокол удаленного рабочего стола.
13. RDS - Remote Desktop Services - службы удаленных рабочих столов.
14. RFC - Request for Comments - документ с технической спецификацией.
15. RTO - Recovery Time Objective - целевое время восстановления.
16. TOTP - Time based One Time Password - одноразовый пароль на основе времени.
17. TPM - Trusted Platform Module - доверенный платформенный модуль.

ВВЕДЕНИЕ

Актуальность темы исследования. В современных условиях цифровой трансформации экономики и перехода большинства организаций на автоматизированные системы управления, проблема обеспечения информационной безопасности становится одной из приоритетных. Ключевым элементом корпоративной информационной инфраструктуры является доменная служба каталогов Active Directory в дальнейшем как AD, которая обеспечивает централизованное управление учетными записями пользователей, правами доступа и политиками безопасности.

Статистика инцидентов информационной безопасности демонстрирует устойчивый рост атак, направленных на компрометацию учетных записей пользователей, особенно имеющих привилегированный доступ к доменной инфраструктуре. Согласно данным исследований, с различными инцидентами, связанными с доменной инфраструктурой, сталкиваются более 37% организаций, при этом в 60% случаев последствием становится недоступность ключевых сервисов, а в 20% прямые финансовые потери.

Особую озабоченность вызывает тот факт, что традиционная однофакторная аутентификация на основе пароля является недостаточно надежной. Пароли подвержены компрометации через фишинг, перехват данных, подбор пароля - Brute Force, а также страдают от человеческого фактора - использования простых и повторяющихся паролей. В этих условиях внедрение двухфакторной аутентификации в дальнейшем как 2FA становится не рекомендацией, а объективной необходимостью для обеспечения базового уровня защиты доменной инфраструктуры.

Среди существующих решений для реализации 2FA в среде AD особого внимания заслуживает открытый программный комплекс MultiOTP, который поддерживает протокол Time based One Time Password в дальнейшем TOTP, интегрируется с AD через LDAP и предоставляет как серверную, так и

клиентскую часть. Открытый исходный код, возможность локального развертывания и отсутствие лицензионных платежей делают MultiOTP оптимальным выбором для внедрения в организациях с ограниченным бюджетом, включая образовательные учреждения и малый бизнес.

Таким образом, тема дипломной работы, посвященная разработке и внедрению сервиса 2FA для доменной инфраструктуры на базе AD с использованием MultiOTP, является актуальной и имеет практическую значимость.

Объект исследования - доменная инфраструктура на базе службы каталогов AD.

Предмет исследования - процесс внедрения 2FA в доменную среду с использованием программного комплекса MultiOTP.

Цель дипломной работы - разработка и внедрение сервиса 2FA для доменной инфраструктуры на базе AD с использованием программного комплекса MultiOTP, обеспечивающего повышение уровня информационной безопасности организации.

Задачи дипломной работы:

Для достижения поставленной цели необходимо решить следующие задачи:

1. Провести анализ доменной инфраструктуры как объекта защиты информационной безопасности.
2. Выполнить анализ актуальных угроз информационной безопасности, характерных для доменной среды, включая атаки на механизмы аутентификации такие как Pass the Hash, Brute Force, фишинг.
3. Изучить теоретические основы двухфакторной аутентификации, протокол TOTP и особенности его применения в доменной среде.

4. Провести сравнительный анализ существующих решений для 2FA и обосновать выбор MultiOTP.
5. Спроектировать архитектуру сервиса 2FA на базе MultiOTP.
6. Реализовать серверную часть системы, установка и настройка MultiOTP, интеграция с AD через LDAP.
7. Настроить клиентскую часть, развертывание Credential Provider на сервере терминалов, регистрация пользователей с использованием TOTP приложений.
8. Выполнить тестирование разработанного решения, включая проверку штатных и нештатных сценариев аутентификации.
9. Разработать эксплуатационную документацию для администратора и пользователя.

Методы исследования и проектирования:

- В процессе выполнения дипломной работы использовались следующие методы:
- анализ научно-технической литературы и документации по теме исследования;
- сравнительный анализ существующих программных решений для 2FA;
- метод проектирования архитектуры информационных систем;
- экспериментальное моделирование, развертывание тестовой среды;
- метод тестирования программного обеспечения;
- анализ результатов тестирования и оценка эффективности.

Практическая значимость работы заключается в том, что разработанный сервис 2FA может быть внедрен в реальную доменную инфраструктуру организации таких как образовательного учреждения, малого предприятия с минимальными затратами, поскольку выбранное решение MultiOTP является

открытым и бесплатным. В работе также представлены инструкции по установке, настройке и эксплуатации системы, что позволяет тиражировать полученный опыт.

Структура дипломной работы обусловлена целью и поставленными задачами. Работа состоит из введения, двух глав, заключения, списка использованной литературы и приложений.

- Первая глава содержит теоретическое обоснование работы, анализ доменной инфраструктуры как объекта защиты, классификацию угроз, теоретические основы 2FA и протокола TOTP, а также сравнительный анализ существующих решений с обоснованием выбора MultiOTP.
- Вторая глава посвящена практической реализации,,: проектированию архитектуры, установке и настройке серверной части MultiOTP, интеграции с AD, настройке клиентской части, тестированию разработанного решения и документированию.
- Заключение содержит основные выводы по результатам выполненной работы и оценку достижения поставленной цели.

Апробация результатов. Основные этапы и результаты дипломной работы были апробированы в период прохождения преддипломной практики, о чем свидетельствует соответствующий план-график практики, включающий такие этапы, как: анализ доменной инфраструктуры, установка и настройка MultiOTP, интеграция с AD, тестирование двухфакторного входа, обучение пользователей и оформление технической документации.

Глава 1. Теоретические основы обеспечения безопасности доменной инфраструктуры и применения двухфакторной аутентификации

1.1 Анализ доменной инфраструктуры как объекта защиты

1.1.1 Назначение и архитектура службы каталогов AD

Active Directory в дальнейшем AD представляет собой службу каталогов, разработанную корпорацией Microsoft для централизованного управления ресурсами в сетях на базе операционных систем Windows Server. Основным назначением AD является хранение информации об объектах доменной инфраструктуры - пользователях, группах, компьютерах, принтерах, серверах и предоставление механизмов для аутентификации и авторизации субъектов доступа.

Архитектура AD базируется на следующих ключевых компонентах:

- Контроллер домена (Domain Controller)- сервер, который хранит базу данных AD и предоставляет службы аутентификации и каталога. Контроллер домена отвечает за проверку учетных данных пользователей при входе в систему, а также за репликацию изменений между несколькими контроллерами в домене.
- Служба каталогов - хранилище объектов, организованных в иерархическую структуру. Домен является основным административным контейнером, который может содержать организационные единицы (Organizational Units) для группировки объектов.
- Механизмы аутентификации - AD поддерживает два основных протокола аутентификации:
 - Kerberos - основной протокол аутентификации в современных версиях Windows, использующий систему билетов и не передающий пароль по сети в открытом виде.

- NTLM (NT LAN Manager) - устаревший, но все еще поддерживаемый протокол, используемый для обратной совместимости. NTLM более уязвим для атак типа Pass the Hash.

Централизованное управление учетными записями и политиками безопасности является ключевым преимуществом AD. Администратор может управлять правами доступа, применять групповые политики (GPO) и контролировать соблюдение политик паролей для всех компьютеров и пользователей домена из единой точки.

1.1.2 Значение AD в обеспечении безопасности организации

В современной корпоративной информационной системе контроллер домена является критическим активом. Компрометация контроллера домена или учетной записи администратора домена фактически означает полную потерю контроля над всей IT инфраструктурой организации.

Централизация управления доступом позволяет:

- применять единые политики безопасности для всех пользователей;
- управлять доступом к ресурсам на основе ролей - RBAC;
- вести централизованный аудит событий безопасности.

Однако централизация создает и серьезные риски. Компрометация доменной учетной записи пользователя, особенно с привилегиями администратора дает злоумышленнику возможность:

- получить несанкционированный доступ к конфиденциальным данным;
- изменить или удалить критически важную информацию;
- распространить вредоносное программное обеспечение на все компьютеры домена;
- использовать скомпрометированную учетную запись для атак на другие системы.

Влияние атак на контроллер домена на всю ИТ инфраструктуру трудно переоценить. Атаки типа Golden Ticket или Silver Ticket позволяют злоумышленнику, получившему доступ к хэсам Kerberos, создавать поддельные билеты для любого пользователя, включая администратора домена. Последствиями таких атак могут стать полная остановка бизнес-процессов, утечка данных и значительные финансовые потери.

1.1.3 Обоснование необходимости усиления защиты учетных записей

Традиционная однофакторная аутентификация на основе пароля имеет ряд фундаментальных недостатков, которые делают ее недостаточной для защиты современных корпоративных систем:

1. Уязвимость паролей - пароли могут быть подобраны (Brute Force), перехвачены с помощью кейлоггеров или украдены из небезопасных хранилищ.
2. Человеческий фактор - пользователи склонны использовать простые, легко запоминающиеся пароли, повторно использовать один и тот же пароль на разных ресурсах, записывать пароли на стикеры, приклеенные к монитору.
3. Ограниченность парольных политик - даже самые строгие политики паролей где минимальная длина 8-14 символов, требование использовать заглавные и строчные буквы, цифры и специальные символы, регулярная смена паролей не защищают от фишинга или перехвата хэша.

В ходе анализа текущей доменной инфраструктуры ИП Сокова Е.А., проведенного 20 апреля 2026 года, были выявлены следующие характеристики (см. таблицу 1.1).

Таблица 1.1 - Характеристики доменной инфраструктуры

Параметр	Значение
Контроллер домена	PDC01

Кол-во пользователей	15+
Мин. длина пароля	8 символов
Макс. срок действия пароля	90 дней
Сложность пароля	Требуется (ComplexityEnabled = True)
Блокировка после неверных попыток	3 попытки

Несмотря на формальное соблюдение рекомендаций по настройке парольной политики, данная конфигурация не защищает от угроз, связанных с перехватом хэшей - Pass the Hash, фишингом или использованием вредоносного программного обеспечения для кражи учетных данных.

Таким образом, внедрение 2FA является необходимым шагом для повышения уровня защищенности доменной инфраструктуры. 2FA требует от пользователя подтверждения подлинности с использованием двух различных факторов, что он знает пароль и что у него есть например, одноразовый код из мобильного приложения. Даже если пароль будет скомпрометирован, злоумышленник не сможет получить доступ к системе без второго фактора.

В рамках данной дипломной работы рассматривается внедрение 2FA на базе открытого программного комплекса MultiOTP с использованием протокола Time based One Time Password в дальнейшем TOTP и интеграцией с существующей инфраструктурой AD.

1.2 Анализ угроз информационной безопасности доменной инфраструктуры

1.2.1 Классификация актуальных угроз для доменной среды

Для обоснования необходимости внедрения 2FA необходимо построить модель угроз, характерных для доменной инфраструктуры организации. В ходе анализа, проведенного 21 апреля 2026 года на базе ИП Сокова Е.А., были выделены следующие основные активы, подлежащие защите:

- доменные учетные записи пользователей;

- база клиентов организации;
- бухгалтерская база данных;
- конфигурационные файлы и политики безопасности.

Угрозы информационной безопасности для доменной инфраструктуры можно классифицировать по источнику возникновения на три основные группы.

Внутренние угрозы исходят от сотрудников организации или лиц, имеющих легитимный доступ к информационной системе. К ним относятся:

- ошибки администрирования, некорректная настройка прав доступа, неосторожные действия при обслуживании контроллера домена;
- злоупотребление правами доступа со стороны сотрудников, имеющих привилегированные учетные записи;
- неосторожные действия пользователей, переход по фишинговым ссылкам, установка небезопасного ПО;
- утрата мобильных устройств, используемых для генерации TOTP кодов актуально для внедряемой системы 2FA.

Внешние угрозы исходят от злоумышленников, не имеющих легитимного доступа к системе. К ним относятся:

- фишинговые атаки, направленные на кражу паролей пользователей;
- перебор паролей с использованием автоматизированных средств;
- эксплуатация уязвимостей в программном обеспечении контроллера домена и клиентских систем;
- атаки типа Man in the Middle для перехвата трафика аутентификации.

Компрометация учетных записей администраторов занимает особое место в классификации, поскольку является наиболее критичной с точки зрения последствий. Учетные записи администраторов домена, Domain Admins, Enterprise Admins предоставляют злоумышленнику неограниченный доступ ко всем ресурсам организации.

1.2.1.1 Модель нарушителя и оценка рисков

Для обоснования необходимости внедрения 2FA была построена модель нарушителя, учитывающая категории лиц, которые могут представлять угрозу для доменной инфраструктуры (см. таблицу 1.2).

Таблица 1.2 - Модель нарушителя

Тип нарушителя	Уровень доступа	Возможности
Внешний злоумышленник	Нет доступа к сети	Атаки через интернет (фишинг, подбор паролей)
Внутренний нарушитель - пользователь	Стандартные права в домене	Попытка повышения привилегий, неосторожные действия
Внутренний нарушитель - администратор	Высокие привилегии	Злоупотребление правами, намеренная компрометация

На основе модели нарушителя и выявленных уязвимостей (раздел 1.2.3) выполнена оценка рисков до и после внедрения 2FA.

1.2.2 Технические атаки на механизмы аутентификации

В ходе анализа были рассмотрены следующие технические атаки на механизмы аутентификации Windows.

Brute Force и Credential Stuffing. Атака подбора пароля заключается в последовательном переборе всех возможных комбинаций символов или использовании словарей распространенных паролей. Credential Stuffing - разновидность атаки, при которой злоумышленник использует учетные данные, украденные с других ресурсов, рассчитывая на то, что пользователи повторно используют одни и те же пароли на разных сервисах. Существующая в ИП Сокова Е.А. политика блокировки учетной записи после 3 неудачных попыток снижает, но не исключает полностью данный тип угроз.

Pass the Hash. Данная атака является одной из наиболее опасных для доменных сред, использующих протокол NTLM. При аутентификации по

протоколу NTLM пароль пользователя не передается по сети - вместо этого передается его хэш. При успешном перехвате или извлечении хэша, например, из файла SAM, злоумышленник может использовать его для аутентификации на других системах без необходимости знать исходный пароль. Внедрение 2FA эффективно противодействует атаке Pass the Hash, поскольку даже при наличии корректного хэша пароля злоумышленник не сможет предоставить второй фактор TOTP код. Важно отметить, что 2FA защищает от атаки Pass the Hash следующим образом, даже если злоумышленник перехватил хэш пароля пользователя, он не сможет пройти аутентификацию, так как для входа требуется TOTP код, который генерируется на отдельном устройстве пользователя. Однако 2FA не защищает от атаки Golden Ticket в случае, если злоумышленник уже получил хэш krbtgt и создал поддельный билет. В этом случае второй фактор может не запрашиваться, так как аутентификация проходит на уровне Kerberos. Это ограничение следует учитывать при построении комплексной системы безопасности. Дополнительными мерами защиты являются: регулярная смена пароля krbtgt, использование защищенных административных рабочих станций PAW и ограничение времени жизни билетов.

Перехват учетных данных. Кейлогеры - это вредоносные программы, которые записывают все нажатия клавиш на компьютере пользователя, включая вводимые пароли. Установка кейлоггера может быть осуществлена как через вредоносное ПО, так и физически аппаратные кейлоггеры. Двухфакторная аутентификация с использованием TOTP кодов, генерируемых на отдельном мобильном устройстве, делает кейлоггеры малоэффективными, так как одноразовый код имеет ограниченное время жизни, как правило, 30 секунд.

Особенности атак на протокол Kerberos. Протокол Kerberos, являясь основным протоколом аутентификации в современных версиях Windows, также имеет уязвимости. Наиболее известные атаки включают:

- Golden Ticket - атака, при которой злоумышленник, получивший доступ к хэшу krbtgt, это учетная запись службы распространения билетов Kerberos, может создать поддельный билет для любого пользователя, включая администратора домена.
- Silver Ticket - атака, при которой создается поддельный билет для доступа к конкретному сервису, например, файловому серверу без обращения к контроллеру домена.

1.2.3 Недостатки однофакторной парольной аутентификации

Проведенный анализ позволяет систематизировать недостатки традиционной однофакторной аутентификации на основе пароля.

Уязвимость паролей. Пароли могут быть подобраны с использованием словарных атак, перехвачены при передаче по незащищенным каналам связи, извлечены из дампов памяти или файлов подкачки, украдены из баз данных, где они хранятся в незашифрованном или слабозашифрованном виде.

Человеческий фактор. Пользователи являются самым слабым звеном в любой системе безопасности. Исследования показывают, что большинство пользователей:

- используют простые пароли, легко поддающиеся подбору , например, «123456», «password», «qwerty»;
- повторно используют один и тот же пароль на нескольких ресурсах;
- записывают пароли на бумажные стикеры, приклеенные к монитору или клавиатуре;
- сообщают свои пароли третьим лицам под различными предлогами, социальная инженерия;
- игнорируют требования к регулярной смене паролей или изменяют пароли незначительно, например, «Password1» на «Password2».

Ограниченность парольных политик. Даже самые строгие парольные политики имеют объективные ограничения. Увеличение минимальной длины

пароля до 12-14 символов и требование использования символов разных классов усложняет жизнь пользователям, но не защищает от перехвата пароля кейлоггером или фишинговой атакой. Кроме того, слишком сложные пароли приводят к тому, что пользователи записывают их на стикеры или хранят в незащищенных файлах.

Результаты анализа текущей конфигурации. В ходе обследования доменной инфраструктуры ИП Сокова Е.А. было установлено, что текущая политика паролей имеет следующие параметры (см. таблицу 1.3).

Таблица 1.3 - Текущая конфигурация политика паролей

Параметр	Текущее значение	Комментарий
Минимальная длина пароля	8 символов	Недостаточно для защиты от перебора
Максимальный срок действия	90 дней	Снижает, но не исключает компрометацию
Сложность пароля	Требуется	Требуется наличия букв, цифр и спецсимволов
Блокировка после неверных попыток	3 попытки	Снижает риск подбора, но не защищает от других атак

Вывод. Существующая конфигурация не защищает от кражи учетных данных с помощью фишинга, кейлоггеров и атак типа Pass the Hash. Указанные недостатки обосновывают необходимость внедрения двухфакторной аутентификации, которая будет рассмотрена в следующем разделе.

1.3 Теоретические основы двухфакторной аутентификации

1.3.1 Понятие и принципы многофакторной аутентификации

Аутентификация представляет собой процедуру проверки подлинности субъекта доступа на основе предъявленных им идентификационных

признаков. В основе современных систем аутентификации лежат три классических фактора:

1. Фактор знания это то что пользователь знает - информация, известная только пользователю: пароль, PIN код, ответ на секретный вопрос. Данный фактор является наиболее распространенным, но и наиболее уязвимым, поскольку информация может быть украдена, подобрана или выведена методами социальной инженерии.
2. Фактор владения то что пользователь имеет - физический объект, находящийся во владении пользователя: мобильный телефон, аппаратный токен, смарт карта. Компрометация данного фактора требует физического доступа к устройству или его удаленного взлома, что существенно сложнее.
3. Фактор наследования то что является частью пользователя - биометрические характеристики: отпечаток пальца, рисунок радужной оболочки глаза, голос, лицо. Этот фактор сложно подделать, но биометрические данные невозможно изменить в случае компрометации.

Двухфакторная аутентификация 2FA - это метод проверки подлинности, при котором используются два фактора из разных категорий. Наиболее распространенной коммерческой реализацией 2FA является комбинация пароля (фактор знания) и одноразового кода из мобильного приложения (фактор владения).

Многофакторная аутентификация MFA - более широкое понятие, охватывающее использование двух и более факторов. Ключевое отличие 2FA от MFA заключается в том, что 2FA использует ровно два фактора, в то время как MFA может использовать три и более. В корпоративной среде MFA с контекстным анализом позволяет применять адаптивные политики безопасности, строже для привилегированных учетных записей, мягче для рядовых пользователей в доверенной сети.

Эффективность многофакторной аутентификации подтверждается статистикой. Согласно отчету Microsoft, внедрение MFA позволяет блокировать более 99,9% атак на учетные записи. Даже если пароль будет скомпрометирован, злоумышленник не сможет получить доступ к системе без второго фактора.

1.3.2 Протокол TOTP как механизм реализации 2FA

Time based One Time Password TOTP - это алгоритм генерации одноразовых паролей на основе временной метки. Протокол стандартизирован Internet Engineering Task Force как RFC 6238 и является одним из наиболее распространенных способов реализации двухфакторной аутентификации. TOTP основан на алгоритме HOTP HMAC based One Time Password, определенном в RFC 4226, но использует вместо счетчика значение, зависящее от времени.

Принцип работы TOTP

Основная формула TOTP может быть представлена следующим образом:

$$\text{TOTP} = \text{Truncate}(\text{HMAC-SHA-1}(K, T))$$

где:

- K - секретный ключ, уникальный для каждого пользователя;
- T - значение временного интервала, вычисляемое по формуле:

$$T = (\text{CurrentTime} - T_0) / X$$

где:

- CurrentTime - текущее время в секундах с 1 января 1970 года, Unix timestamp;
- T₀ - начальная точка отсчета времени (по умолчанию 0);
- X - длина временного интервала в секундах (по умолчанию 30 секунд).

Этапы работы TOTP в системе двухфакторной аутентификации:

1. Инициализация - при первом включении 2FA для пользователя генерируется уникальный секретный ключ. Ключ кодируется в формате Base32 и представляется в виде QR кода для удобного сканирования мобильным приложением.
2. Привязка устройства - пользователь сканирует QR код приложением аутентификатором Google Authenticator, Microsoft Authenticator и др. Приложение сохраняет секретный ключ локально на устройстве.
3. Генерация кода - приложение аутентификатор периодически например каждые 30 секунд генерирует 6 значный одноразовый код на основе секретного ключа и текущего времени.
4. Проверка кода - при попытке входа в систему пользователь вводит пароль и текущий TOTP код. Сервер, зная секретный ключ пользователя, выполняет независимый расчет и сравнивает полученное значение с введенным.

Преимущества TOTP перед SMS аутентификацией

В ходе сравнительного анализа были выявлены следующие преимущества TOTP (см.таблицу 1.4).

Таблица 1.4 - Преимущества TOTP

Критерий	TOTP	SMS
Защита от перехвата	Высокая, код не передается по сети	Низкая, уязвимость SS7, SIM swap
Зависимость от сотовой связи	Отсутствует	Полная зависимость
Стоимость для организации	Бесплатно	Требуется оплата SMS рассылки
Защита от фишинга	Частичная, код привязан к конкретному ресурсу	Низкая
Работа офлайн	Поддерживается	Не поддерживается

Критерий	TOTP	SMS
Удобство для пользователя	Требуется установка приложения	Не требует дополнительного ПО

Согласно современным исследованиям в области информационной безопасности, SMS коды считаются устаревшим и архитектурно ненадежным методом двухфакторной аутентификации. TOTP, напротив, обеспечивает баланс между безопасностью и удобством использования, что делает его оптимальным выбором для корпоративных внедрений.

Безопасность TOTP

Несмотря на высокую надежность, TOTP не лишен некоторых уязвимостей:

- Коды TOTP, как и любые пароли, могут быть украдены с помощью фишинга, но требуют от злоумышленника немедленного использования в течение 30-60 секунд в зависимости от настроек.
- При неограниченном количестве попыток ввода возможен перебор кодов $10^6 = 1\,000\,000$ комбинаций.
- При компрометации секретного ключа злоумышленник может генерировать корректные TOTP коды.

Внедряемая система должна учитывать данные уязвимости: ограничивать количество попыток ввода, обеспечивать безопасное хранение секретных ключей и предусматривать процедуры восстановления доступа.

1.3.3 Особенности внедрения 2FA в доменной инфраструктуре

Интеграция 2FA с AD представляет собой задачу модификации стандартного процесса входа в операционную систему Windows.

Стандартный процесс аутентификации в Windows

Штатный процесс входа пользователя в Windows включает следующие основные компоненты:

- Winlogon - менеджер входа, отвечающий за загрузку интерфейса входа и обработку сеанса пользователя.
- Credential Providers - программные компоненты, реализующие интерфейс для ввода учетных данных. Windows поддерживает несколько Credential Providers, что позволяет добавлять сторонние решения для аутентификации. При вводе имени пользователя и пароля Winlogon вызывает соответствующий Credential Provider, который обрабатывает полученные данные и передает их на проверку.

Особенности аутентификации при RDP доступе

В инфраструктуре ИП Сокова Е.А. все сотрудники подключаются к рабочей среде через протокол удаленного рабочего стола (RDP) к серверу терминалов. При RDP подключении клиентское устройство передает учетные данные (логин и пароль) на сервер терминалов, где процесс аутентификации выполняется штатными компонентами Windows (Winlogon и Credential Providers). Это означает, что:

- Credential Provider MultiOTP устанавливается не на каждое клиентское устройство, а только на сервер терминалов RDS.
- Пользователи могут подключаться с любых устройств такие как тонкие клиенты, ПК, ноутбуки, планшеты, без необходимости установки дополнительного программного обеспечения.
- Двухфакторная аутентификация одинаково корректно работает как при локальном входе на сервер, так и при удаленных подключениях через RDP.

Изменение процесса аутентификации при внедрении 2FA на базе MultiOTP

Внедрение 2FA на базе MultiOTP модифицирует процесс входа следующим образом:

1. Запрос учетных данных - при подключении пользователя по RDP Winlogon отображает стандартное окно входа. Пользователь вводит логин и пароль AD.
2. Проверка пароля - Credential Provider MultiOTP передает введенные данные в MultiOTP Service. Служба выполняет LDAP запрос к контроллеру домена для проверки подлинности пароля.
3. Запрос TOTP кода - если пароль верен, Credential Provider отображает второе окно, в котором пользователь вводит 6 значный TOTP код из приложения аутентификатора.
4. Проверка TOTP кода - MultiOTP Service считывает секретный ключ пользователя из локального хранилища (папка C:\Program Files\MultiOTP\users\[username].db), вычисляет ожидаемый код в соответствии с RFC 6238 и сравнивает его с введенным пользователем.

Принятие решения - если оба фактора, пароль и TOTP код верны, доступ к системе разрешается. В противном случае отклоняется.

Схема процесса аутентификации

На рисунке 1.1 представлена упрощенная схема процесса аутентификации с использованием двух факторов (см. рисунок 1.1).

Процесс аутентификации пользователя с 2FA

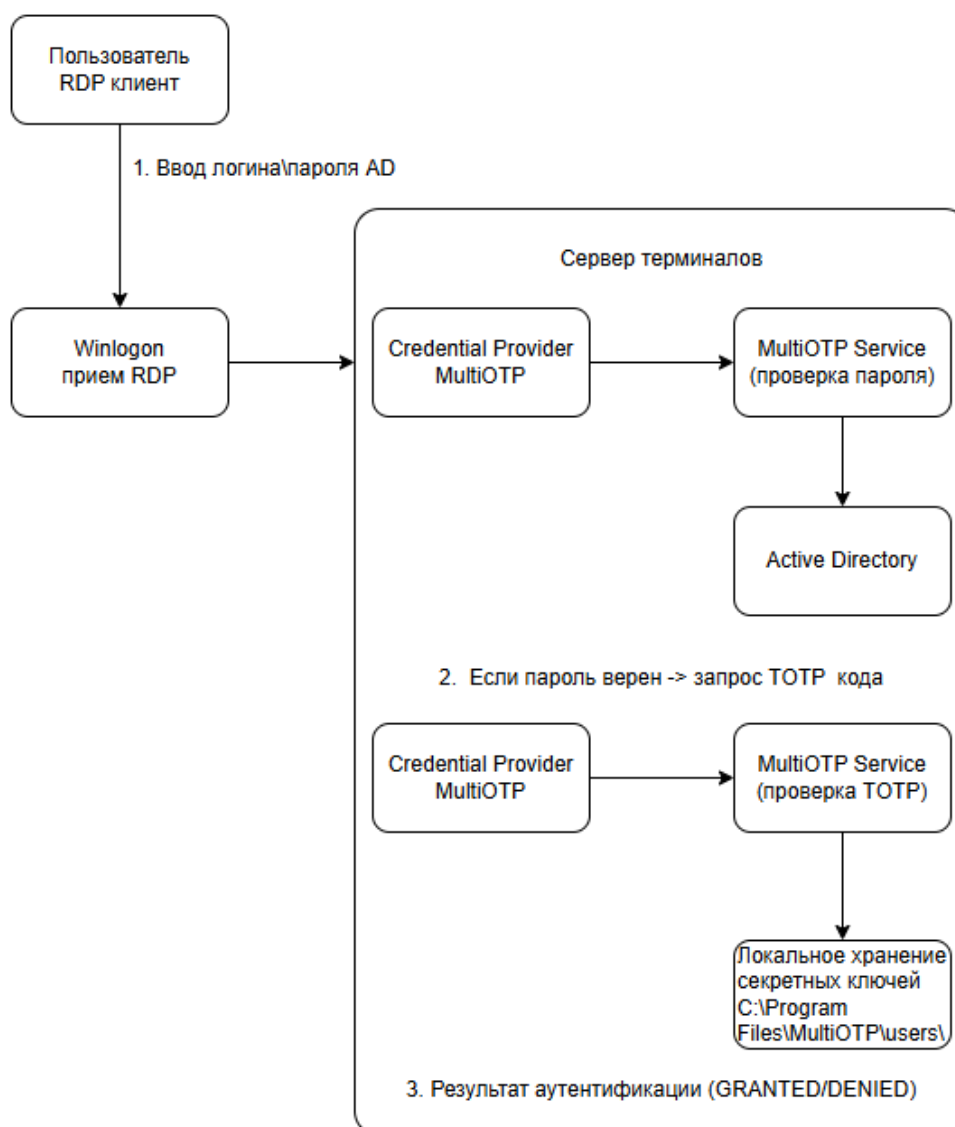


Рисунок 1.1 - Процесс аутентификации пользователя с двухфакторной аутентификацией

Интеграция с контроллером домена через LDAP

Для проверки первого фактора (пароля) MultiOTP использует протокол Lightweight Directory Access Protocol в дальнейшем LDAP. При вводе пароля MultiOTP направляет LDAP запрос к контроллеру домена с использованием сервисной учетной записи. Контроллер домена возвращает результат

аутентификации (успех/неудача), не передавая сам пароль по сети в открытом виде.

Преимущества использования LDAP:

- централизованная проверка паролей без дублирования учетных записей;
- синхронизация списка пользователей и групп с AD;
- применение существующих политик безопасности домена.

Потенциальные сложности внедрения и способы их решения

В ходе проектирования были выявлены следующие потенциальные сложности внедрения 2FA в доменной инфраструктуре:

1. Потеря пользователем мобильного устройства - без доступа к TOTP приложению пользователь не может выполнить вход. Решение: генерация резервных кодов для каждого пользователя (по 10 кодов), которые можно использовать для входа в экстренных случаях, а также процедура восстановления доступа администратором через веб-консоль.
2. Влияние на пользовательский опыт - дополнительный шаг аутентификации увеличивает время входа. В ходе анализа производительности (раздел 2.4) было установлено, что увеличение времени входа составляет менее 0,5 секунды, что незаметно для пользователя.
3. Ввод TOTP кода при RDP подключении - стандартный RDP клиент не поддерживает отдельное поле для TOTP кода. Решение: Credential Provider MultiOTP отображает второе окно для ввода TOTP кода после успешной проверки пароля. Это не требует изменений на стороне RDP клиента.

Вывод по разделу

Двухфакторная аутентификация на основе протокола TOTP и программного комплекса MultiOTP является эффективным методом

повышения безопасности доменной инфраструктуры при RDP доступе. Интеграция 2FA с AD через Credential Provider и LDAP не требует существенных изменений существующей инфраструктуры и может быть выполнена с минимальными затратами при использовании открытого программного обеспечения. Установка Credential Provider только на сервер терминалов, а не на каждое клиентское устройство, упрощает развертывание и централизует управление политикой 2FA.

1.4 Сравнительный анализ решений 2FA для доменной среды

1.4.1 Критерии сравнения программных продуктов

Для обоснованного выбора программного решения для внедрения 2FA в доменной инфраструктуре ИП Сокова Е.А. был проведен сравнительный анализ доступных на рынке продуктов. Выбор критериев основывался на технических требованиях, выявленных в ходе анализа инфраструктуры, а также на ограничениях, связанных с бюджетом и компетенциями организации.

Были выделены следующие критерии сравнения:

1. Поддержка интеграции с AD - возможность проверки первого фактора (пароля) через существующую доменную инфраструктуру без дублирования учетных записей.
2. Поддержка TOTP - использование стандартного протокола TOTP (RFC 6238) для генерации одноразовых паролей, что обеспечивает совместимость с широким спектром мобильных приложений аутентификаторов (Google Authenticator, Microsoft Authenticator и др.).
3. Наличие Credential Provider для Windows - возможность интеграции непосредственно в процесс входа в операционную систему Windows локально и через RDP, без использования дополнительных компонентов, таких как RADIUS серверы.

4. Стоимость внедрения и владения - лицензионные платежи, стоимость поддержки и обновлений, а также скрытые затраты на инфраструктуру.
5. Открытость исходного кода - возможность аудита безопасности, модификации и бесплатного использования.
6. Возможность локального развертывания - отсутствие обязательной привязки к облачным сервисам, что критично для организаций с требованиями к изоляции данных или нестабильным интернет соединением.
7. Поддержка аппаратных токенов - возможность использования не только программных TOTP генераторов, но и специализированных аппаратных устройств, что может потребоваться для административных или служебных учетных записей.
8. Соответствие требованиям импортозамещения - для российских организаций актуальна возможность использования решений из реестра отечественного ПО.

1.4.2 Обзор существующих решений

В ходе анализа были рассмотрены следующие программные продукты, предоставляющие возможность 2FA для Windows клиентов в доменной среде.

1. MultiOTP

MultiOTP - это открытое решение, разработанное компанией SysCo systèmes de communication sa. Представляет собой PHP класс, мощную утилиту командной строки и веб-интерфейс для управления. Поддерживает различные алгоритмы OTP, включая OATH/HOTP, OATH/TOTP и mOTP (Mobile OTP). Хранение данных по умолчанию осуществляется на основе плоских файлов (flat files), что позволяет развернуть решение за несколько минут. В состав решения входит Credential Provider для Windows, который встраивается в процесс входа Winlogon и взаимодействует со службой MultiOTP для проверки двух факторов. MultiOTP распространяется под лицензией GNU

LGPL, что делает его полностью бесплатным для коммерческого использования.

2. Duo Security

Duo Security - коммерческое решение, предоставляющее широкий спектр методов многофакторной аутентификации. Duo предлагает интеграцию с AD через Duo Authentication Proxy и имеет Credential Provider для Windows. Решение поддерживает push уведомления, SMS, телефонные звонки и TOTP. Основным недостатком является платная модель лицензирования (от \$3/мес/пользователь), а также зависимость от облачной инфраструктуры Duo, возможно локальное развертывание Duo Beyond, но требует дополнительных затрат.

3. Microsoft Windows Hello for Business (WHfB)

Windows Hello for Business - встроенное решение Microsoft, использующее биометрию или PIN код в качестве второго фактора. Требуется наличия TPM 2.0 - Trusted Platform Module на клиентских устройствах и гибридной или полностью облачной инфраструктуры с Azure AD. WHfB не поддерживает TOTP, что ограничивает его использование на устройствах без TPM и при необходимости использования мобильных приложений-аутентификаторов.

4. privacyIDEA

privacyIDEA - открытое решение для многофакторной аутентификации, написанное на Python. Поддерживает множество токенов (TOTP, HOTP, YubiKey и др.) и может интегрироваться с AD. Однако для интеграции с Windows необходима дополнительная настройка RADIUS сервера или сторонних Credential Provider, так как встроенного компонента для Windows входа не предусмотрено. Это усложняет внедрение и увеличивает количество компонентов в инфраструктуре.

5. Российские решения (MULTIFACTOR, Рутокен MFA)

На российском рынке представлены решения, включенные в реестр отечественного ПО: MULTIFACTOR от компании «Крипто-Про» и Рутокен MFA от «Актив». Данные решения поддерживают интеграцию с AD и предоставляют широкий спектр методов аутентификации, включая TOTP, push уведомления и аппаратные токены. Основными недостатками являются стоимость лицензирования и необходимость приобретения аппаратных токенов для полного использования функционала.

1.4.3 Сравнительная таблица решений

На основе проведенного анализа составлена сравнительная таблица решений по выделенным критериям (см. таблица 1.5).

Таблица 1.5 - Сравнительная таблица решений 2FA

Критерий	MultiOTP	Duo Security	WHfB	privacyIDE A	Российские решения
Интеграция с AD	Да, LDAP	Да, прокси	Да, Azure AD	Да, LDAP	Да
Поддержка TOTP	Да	Да	Нет	Да	Да
Credential Provider	Да (встроенный)	Да	Да (встроенный)	Нет (требуется RADIUS)	Да
Стоимость	Бесплатно (GNU LGPL)	От \$3/мес/пользователь	Бесплатно (в составе Windows)	Бесплатно (GPLv3)	Платное
Открытый код	Да (LGPL)	Нет	Нет	Да (GPLv3)	Нет

Локальное развертывание	Да	Ограниченно	Нет (требуется Azure)	Да	Да
Поддержка аппаратных токенов	Да	Да	Да (только TPM)	Да	Да
Импортозамещение	Нет (не в реестре)	Нет	Нет	Нет	Да

1.4.4 Обоснование выбора программного комплекса MultiOTP

На основе проведенного сравнительного анализа для внедрения в рамках дипломной работы был выбран программный комплекс MultiOTP. Выбор обоснован следующими факторами:

1. Соответствие критериям. MultiOTP удовлетворяет всем ключевым критериям, включая интеграцию с AD через LDAP, поддержку TOTP и наличие встроенного Credential Provider для Windows.
2. Нулевая стоимость владения. MultiOTP распространяется под лицензией GNU LGPL, что делает его полностью бесплатным как для использования, так и для модификации. Это критически важно для ИП Сокова Е.А. и может быть полезно для других малых организаций.
3. Возможность локального развертывания. Решение не требует подключения к облачным сервисам и может функционировать полностью в изолированной сети, что повышает уровень контроля над данными и безопасностью.
4. Простота развертывания. Хранение данных на основе плоских файлов позволяет развернуть решение за несколько минут без необходимости настройки отдельной СУБД.
5. Поддержка TOTP. TOTP является открытым стандартом RFC 6238 и поддерживается всеми популярными мобильными приложениями аутентификаторами, включая Google Authenticator и Microsoft Authenticator. Это обеспечивает пользователям возможность выбора удобного для них приложения.

6. Минимальные требования к инфраструктуре. MultiOTP может быть установлен на существующем сервере без необходимости приобретения дополнительного оборудования.
7. Поддержка аппаратных токенов. При необходимости повышения безопасности для административных учетных записей MultiOTP позволяет использовать аппаратные токены (например, Feitian), что подтверждено технической документацией.
8. Наличие Credential Provider. В отличие от privacyIDEA, требующей настройки RADIUS сервера, MultiOTP предоставляет готовый Credential Provider, который напрямую интегрируется с Winlogon, что упрощает архитектуру и снижает количество потенциальных точек отказа.

Вывод по разделу. Выбор MultiOTP в качестве платформы для внедрения 2FA является оптимальным для условий ИП Сокова Е.А. Решение сочетает бесплатность, функциональность и простоту развертывания, что подтверждается его успешным использованием в образовательных и коммерческих организациях.

Выводы по главе 1

В первой главе дипломной работы были рассмотрены теоретические основы обеспечения безопасности доменной инфраструктуры и применения двухфакторной аутентификации.

1. Анализ доменной инфраструктуры показал, что AD является критическим активом организации. Компрометация контроллера домена или учетной записи администратора может привести к полной потере контроля над IT инфраструктурой. Текущая конфигурация ИП Сокова Е.А. политика паролей с минимальной длиной 8 символов, блокировка после 3 попыток, не обеспечивает достаточный уровень защиты.

2. Анализ угроз выявил, что основными рисками для доменной инфраструктуры являются: атаки типа Pass the Hash, фишинг, перебор паролей - Brute Force и кейлоггеры. Данные угрозы не могут быть устранены только за счет усиления парольной политики.
3. Теоретические основы 2FA показали, что двухфакторная аутентификация, основанная на комбинации факторов «знание» пароль и «владение» TOTP код, способна блокировать более 99,9% атак на учетные записи. Протокол TOTP (RFC 6238) является открытым стандартом и имеет преимущества перед SMS-аутентификацией: отсутствие зависимости от сотовой связи, нулевая стоимость, работа в офлайн-режиме.
4. Сравнительный анализ решений позволил обосновать выбор программного комплекса MultiOTP для внедрения. Ключевыми преимуществами выбранного решения являются: открытый исходный код, нулевая стоимость лицензирования, наличие встроенного Credential Provider для Windows, поддержка TOTP и возможность локального развертывания без использования облачных сервисов.

Таким образом, теоретическая часть работы подтверждает актуальность и целесообразность внедрения 2FA в доменной инфраструктуре. На основе проведенного анализа во второй главе будет представлена практическая реализация сервиса 2FA на базе MultiOTP с интеграцией в доменную среду ИП Сокова Е.А.

Глава 2. Разработка и внедрение сервиса 2FA на базе MultiOTP

2.1 Проектирование архитектуры сервиса 2FA

2.1.1 Анализ существующей инфраструктуры

Внедрение сервиса 2FA осуществлялось на базе инфраструктуры ИП Сокова Е.А. В ходе анализа, проведенного 20 апреля 2026 года, были установлены следующие параметры (см. таблица 2.1):

Таблица 2.1 - Характеристики существующей инфраструктуры

Параметр	Значение
Контроллер домена	PDC01.domen.lc
Сервер терминалов (RDS)	TS.domen.lc
Версия ОС серверов	Windows Server 2019
Количество пользователей	15+
Способ доступа к рабочей среде	RDP
Клиентские устройства	Тонкие клиенты, ПК, ноутбуки, планшеты
Функциональный уровень домена	Windows Server 2019
Поддерживаемые протоколы аутентификации	Kerberos, NTLM

Особенности инфраструктуры:

- TPM модули не требуются, так как аутентификация происходит на стороне сервера терминалов;
- Credential Provider устанавливается только на RDS, а не на клиентские устройства;
- Пользователи могут подключаться из любых сетей, в том числе из домашних с любых устройств.

Ключевые требования к внедряемому решению:

Функциональные требования:

- Двухфакторная аутентификация при входе в Windows локально и через RDP;
- Интеграция с существующими учетными записями AD;
- Поддержка TOTP совместимых мобильных приложений (Google Authenticator, Microsoft Authenticator);
- Возможность локального развертывания без облачных сервисов.

Нефункциональные требования:

- Время входа с 2FA не должно превышать время входа без 2FA более чем на 2 секунды;
- Простота администрирования через веб-интерфейс;
- Нулевая стоимость лицензирования.

2.1.2 Общая схема взаимодействия компонентов

На основе анализа требований была спроектирована следующая архитектура сервиса 2FA (рисунок 2.1).

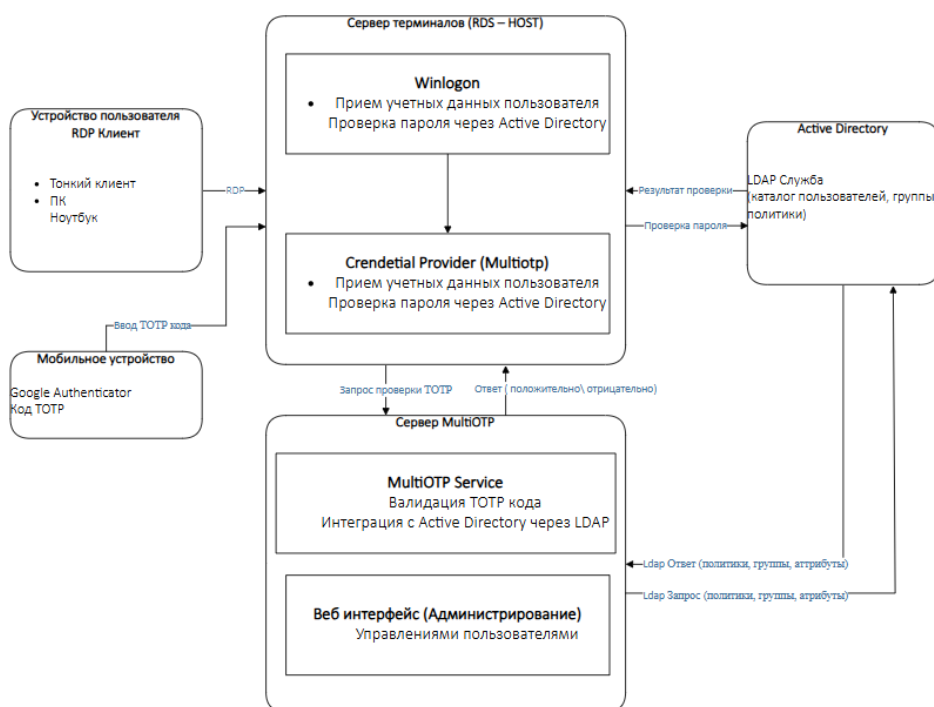


Рисунок 2.1 - Архитектура сервиса 2FA на базе MultiOTP

Описание связей между компонентами:

1. RDP подключение - пользователь подключается с любого устройства к серверу терминалов PDC01 по протоколу удаленного рабочего стола - RDP.
2. Winlogon => Credential Provider - Winlogon принимает RDP подключение и вызывает Credential Provider MultiOTP. Пользователь вводит логин и пароль AD в стандартном окне.
3. Credential Provider => MultiOTP Service - после успешной проверки пароля Credential Provider отображает второе окно для ввода TOTP кода и передает его в MultiOTP Service.
4. MultiOTP Service <==> AD (LDAP) - MultiOTP Service выполняет LDAP-запрос к контроллеру домена (DC01.local) для проверки пароля. Контроллер домена возвращает результат.
5. MultiOTP Service <==> Локальное хранение секретных ключей - MultiOTP Service обращается к папке users/ в своем каталоге установки (C:\Program Files\MultiOTP\users\), где хранятся секретные ключи пользователей в файлах [username].db. На основе секретного ключа и текущего времени служба вычисляет ожидаемый TOTP код и сравнивает его с введенным пользователем.
6. Веб интерфейс - администратор через браузер управляет пользователями, токенами.

2.1.3 Логика работы системы

На рисунке представлена диаграмма последовательности, описывающая полный цикл аутентификации пользователя (см. рисунок 2.2).



Рисунок 2.2 - Диаграмма последовательности аутентификации

Пояснение ключевых этапов:

1. Пользователь подключается по RDP к серверу терминалов PDC01.
2. Пользователь вводит логин и пароль AD.
3. Winlogon передает данные в Credential Provider MultiOTP.
4. Credential Provider передает логин и пароль в MultiOTP Service.
5. MultiOTP Service выполняет LDAP запрос к AD для проверки пароля.
6. AD возвращает результат проверки.
7. Если пароль верен, Credential Provider отображает второе окно для ввода TOTP кода.
8. Пользователь вводит 6 значный код из приложения Google Authenticator.
9. MultiOTP Service считывает секретный ключ пользователя из локального файла users/[username].db в каталоге C:\Program Files\MultiOTP\users\.
10. MultiOTP Service вычисляет ожидаемый TOTP код и сравнивает с введенным.
11. Результат аутентификации передается обратно пользователю.

2.1.4 Обеспечение отказоустойчивости сервиса

В ходе проектирования архитектуры были предусмотрены следующие меры для обеспечения корректной работы сервиса в нештатных ситуациях (см. таблицу 2.2):

Таблица 2.2 - Меры обеспечения отказоустойчивости

Точка отказа	Способ минимизации
Потеря связи с AD	Кэширование данных LDAP, параметр <code>ldap_cache_on=1</code>
Потеря телефона пользователем	Резервные коды 10 штук и процедура восстановления администратором
Отказ сервера MultiOTP	Регулярное резервное копирование папки <code>C:\Program Files\MultiOTP</code> ; план восстановления из резервной копии
Повреждение файлов секретных ключей	Ежедневное резервное копирование; проверка целостности файлов <code>.db</code>
Недоступность веб интерфейса	Управление через командную строку <code>multiotp.exe</code> , резервное копирование конфигурации

В данной дипломной работе развертывание резервного сервера MultiOTP не предусмотрено в связи с небольшим количеством пользователей 15+ и ограниченными бюджетными ресурсами организации. В качестве компенсирующей меры настроено регулярное резервное копирование конфигурации и секретных ключей, что позволяет восстановить работоспособность сервиса в течение 30 минут.

2.1.5 Выводы

Спроектированная архитектура сервиса 2FA на базе MultiOTP:

- не требует использования RADIUS сервера, что упрощает инфраструктуру;

- обеспечивает полную интеграцию с существующей доменной инфраструктурой;
- поддерживает двухэтапный ввод, сначала пароль AD, затем TOTP код;
- не требует установки дополнительного ПО на клиентские устройства;
- все данные, секретные ключи, конфигурация хранятся локально на сервере терминалов.

2.2 Реализация серверной части на базе MultiOTP

2.2.1 Подготовка инфраструктуры

Для развертывания сервиса 2FA была использована следующая инфраструктура (см. таблицу 2.3):

Таблица 2.3 - Характеристики серверной инфраструктуры

Роль	ОС	Адрес	Назначение
Контроллер домена	Windows Server 2019	PDC01.domen.lc	AD
Сервер терминалов (RDS)	Windows Server 2019	TS.domen.lc	Установка Credential Provider
Сервер MultiOTP	Windows Server 2019	Multiotp.domen.lc	Установка MultiOTP Service, Credential Provider, веб-интерфейс, хранение секретных ключей

Требования к серверу MultiOTP:

- ОС: Windows Server 2019, поддерживает Credential Provider;
- Веб сервер: встроенный mongoose не требует отдельной установки IIS;
- Свободное место на диске: минимум 1 ГБ для хранения секретных ключей и логов;
- Сеть: доступ к контроллеру домена по LDAP;
- Права: локальный администратор для установки.

2.2.2 Установка MultiOTP

Для установки использована стабильная версия MultiOTP 5.9.0.1, которая имеет полную поддержку Credential Provider для Windows и интеграцию с AD через LDAP.

Шаг 1. Скачивание дистрибутива

Дистрибутив MultiOTP версии 5.9.0.1 (архив multiotp-5.9.0.1.zip) был скачан с официального репозитория и размещен на сервере терминалов C:\DistrSetup\.

Шаг 2. Установка в целевой каталог

Архив был распакован в каталог C:\Program Files\MultiOTP. Данный каталог содержит следующие ключевые файлы и папки (см. таблицу .2.4)

Таблица 2.4 - Ключевые файлы и папки MultiOTP

Файл/папка	Назначение
multiotp.exe	Основная утилита командной строки и служба аутентификации
multiotp.ini	Файл конфигурации, все настройки сервера
users/	Папка с секретными ключами пользователей, файлы [username].db)
log/	Папка с журналами событий

Шаг 3. Установка службы MultiOTP

Представлена команда, выполненная через командную строку для установки службы MultiOTP и её запуска в режиме службы Windows

(см. рисунок 2.3).

```
Microsoft Windows [Version 10.0.26100.8457]
(c) Корпорация Майкрософт (Microsoft Corporation). Все права
защищены.

C:\Users\Administrator>cd "C:\Program Files\MultiOTP"

C:\Program Files\MultiOTP>

C:\Program Files\MultiOTP>multiotp.exe --install-service
MultiOTP - Open Source strong OTP solution version 5.9.0.1
Copyright (c) 2010-2024 SysCo systèmes de communication sa
Licensed under GNU LGPL

[INFO] Service "multiotp" is not installed
[INFO] Installing service "multiotp"...
[INFO] Service "multiotp" installed successfully
[INFO] Service start type set to "Automatic"

C:\Program Files\MultiOTP>
```

Рисунок 2.3 - Вывод команды установки службы MultiOTP

Шаг 4. Запуск службы

```
C:\Program Files\MultiOTP>net start multiotp
The multiotp service is starting.....
The multiotp service was started successfully.

C:\Program Files\MultiOTP>
```

Рисунок 2.4 - Запуск службы MultiOTP (команда net start)

Шаг 5. Проверка статуса службы (см. рисунок 2.5)

```
C:\Program Files\MultiOTP>sc query multiotp

SERVICE_NAME: multiotp
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 4   RUNNING
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE    : 0   (0x0)
        CHECKPOINT            : 0x0
        WAIT_HINT             : 0x0

C:\Program Files\MultiOTP>
```

Рисунок 2.5 - Проверка статуса службы MultiOTP

Ожидаемый результат: STATE : 4 RUNNING.

Шаг 6. Установка веб интерфейса

Для управления пользователями и токенами через браузер был установлен встроенный веб сервер mongoose (см. рисунок 2.6):

```
C:\Program Files\MultiOTP>multiotp.exe --install-web-interface
MultiOTP - Open Source strong OTP solution version 5.9.0.1
Copyright (c) 2010-2024 SysCo systèmes de communication sa
Licensed under GNU LGPL

[INFO] Web interface installed successfully
[INFO] Web server started on port 8080
[INFO] Access web interface at: http://TS.domen.lc:8080
[INFO] HTTPS not configured (self-signed certificate available)

C:\Program Files\MultiOTP>
```

Рисунок 2.6 - Установка веб интерфейса

Веб интерфейс становится доступен по адресу: <https://10.0.30.69/#>

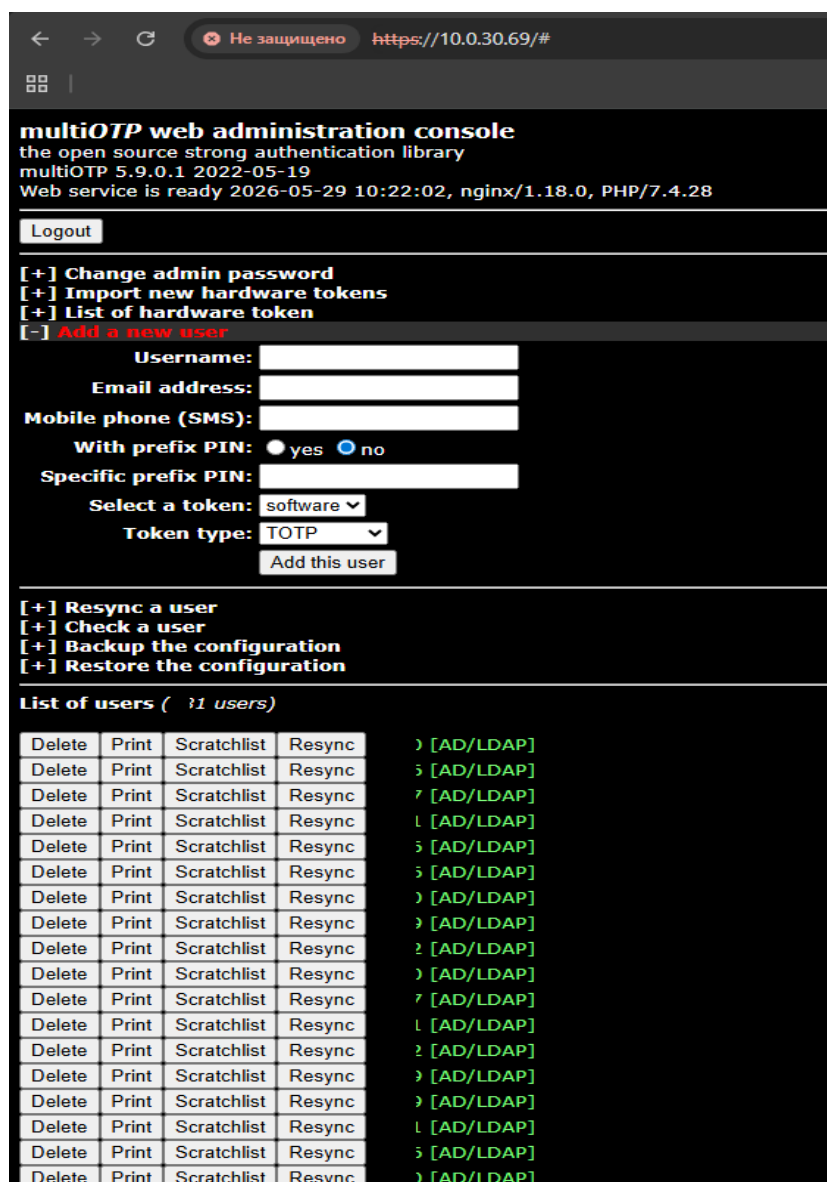


Рисунок 2.7 - Веб интерфейс MiltiOTP

2.2.3 Файл конфигурации multiotp.ini

Файл multiotp.ini является центральным элементом конфигурации сервера. Он расположен в C:\Program Files\MultiOTP\multiotp.ini. Ниже представлен частичный список конфигурации, использованный в проекте, конфиденциальные данные заменены (см. таблицу 2.5).

Файл конфигурации multiotp.ini Приложении А (А.3)

Таблица 2.5 - Пояснение ключевых параметров

Параметр	Значение	Назначение
backend_type=files	Файловое хранение	Хранение TOTP ключей в папке users/
ldap_activated=1	Включена интеграция с AD	Проверка паролей через LDAP
ldap_base_dn	DC=domen.lc	Корень каталога AD
ldap_bind_dn	CN=svc_multiotp,	Служебная учетная запись для доступа к AD
ldap_domain_controllers	pdc01.domen.lc	Адрес контроллера домена
default_algorithm	totp	Используемый алгоритм TOTP, RFC 6238
scratch_passwords_amount	10	Количество резервных кодов на пользователя
max_block_failures	3	Блокировка после 3 неудачных попыток
allow_password_only	0	Запрет входа только по паролю
log	1	Включено ведение журнала событий

2.2.4 Интеграция с AD через LDAP

Для проверки первого фактора (пароля) была выполнена настройка LDAP подключения.

Шаг 1. Создание служебной учетной записи

В AD была создана учетная запись svc_multiotp - сервисная с правами на чтение каталога. Это позволяет MultiOTP выполнять поиск пользователей и проверять их пароли без использования административной учетной записи.

Шаг 2. Настройка параметров LDAP в multiotp.ini

В файл конфигурации были внесены настройки, представленные в листинге 2.1.

Шаг 3. Проверка LDAP аутентификации

Для проверки корректности настроек была выполнена команда через командную строку (см. таблицу 2.8):

```
C:\Program Files\MultiOTP>multiotp.exe --ldap-authenticate user666 P@ssw0rd2024
MultiOTP - Open Source strong OTP solution version 5.9.0.1
Copyright (c) 2010-2024 SysCo systèmes de communication sa
Licensed under GNU LGPL

[LDAP] Connecting to dc01.domen.lc:389
[LDAP] Bind successful for cn=svc_multiotp,cn=Users,dc=domen,dc=lc
[LDAP] Searching for sAMAccountName=user666
[LDAP] User found: CN=User666,CN=Users,DC=domen,DC=lc
[LDAP] Authentication OK for user666
OK

C:\Program Files\MultiOTP>
```

Рисунок 2.8 - Результат проверки LDAP-аутентификации

Ожидаемый вывод: ОК.

2.2.5 Настройка Credential Provider

Credential Provider - ключевой компонент, обеспечивающий появление интерфейса для ввода TOTP кода при входе в систему.

Шаг 1. Установка Credential Provider (см. рисунок 2.9)

```
C:\Program Files\MultiOTP>multiotp.exe --install-credential-provider
MultiOTP - Open Source strong OTP solution version 5.9.0.1
Copyright (c) 2010-2024 SysCo systèmes de communication sa
Licensed under GNU LGPL

[INFO] Credential Provider not found in registry
[INFO] Copying MultiOTPCredentialProvider.dll to system32
[INFO] Registering COM object for MultiOTP Credential Provider
[INFO] Writing registry entries under:
        HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Authentication\Credential Pro
viders
[INFO] Credential Provider installed successfully
[INFO] Please restart Winlogon or reboot the server for changes to take effect

C:\Program Files\MultiOTP>
```

Рисунок 2.9 - Установка Credential Provider

Шаг 2. Проверка установки

Успешная установка добавляет GUID MultiOTP в ветку реестра:

HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Authentication\C
redential Providers

Шаг 3. Настройка multiotp.ini для Credential Provider

В файл конфигурации были внесены настройки (уже представлены в листинге 2.1):

```
[credentialprovider]
enabled=1
prompt_format=Password + 6-digit code
allow_password_only=0
```

enabled=1 - активация Credential Provider;

prompt_format - текст, отображаемый в окне входа;

allow_password_only=0 - запрет входа только по паролю, обязателен TOTP код.

2.2.6 Выводы

В разделе 2.2 выполнены следующие работы:

1. Установлен MultiOTP версии 5.9.0.1 на сервер терминалов PDC01.
2. Настроена служба MultiOTP для работы в фоновом режиме.
3. Установлен веб интерфейс для централизованного управления.
4. Выполнена интеграция с AD через LDAP, настроены параметры.
5. Установлен и настроен Credential Provider для Windows/RDP.

2.3 Настройка клиентской части и регистрация пользователей

2.3.1 Синхронизация пользователей из AD

После настройки LDAP подключения следующим шагом является синхронизация списка пользователей из AD в локальное хранилище MultiOTP (папка users/).

Шаг 1. Ручная синхронизация пользователей

Для первоначальной синхронизации всех пользователей была выполнена команда через командную строку (см. рисунок 2.10).

```
C:\Program Files\MultiOTP>multiotp.exe --ldap-users-sync
MultiOTP - Open Source strong OTP solution version 5.9.0.1
Copyright (c) 2010-2024 SysCo systèmes de communication sa
Licensed under GNU LGPL

[LDAP] Connecting to dc01.domen.lc:389
[LDAP] Bind successful for cn=svc_multiotp,cn=Users,dc=domen,dc=lc
[LDAP] Searching for all users (sAMAccountName=*)
[LDAP] Found 18 users in AD
[SYNC] Processing user: user666 (User666)
[SYNC]   → User added to local storage: C:\Program
Files\MultiOTP\users\user666.db
[SYNC] Processing user: admin_domen
[SYNC]   → User added to local storage
[SYNC] Processing user: svc_multiotp
[SYNC]   → Skipped (service account)
...
[SYNC] Sync completed: 15 users added, 0 updated, 1 skipped (service
accounts)
[SYNC] 2 groups synchronized

C:\Program Files\MultiOTP>
```

Рисунок 2.10 - Ручная синхронизация пользователей

Результат: Все пользователи AD добавлены в локальное хранилище MultiOTP (папка users/).

Шаг 2. Просмотр пользователей в веб-консоли

После синхронизации все пользователи AD отображаются в веб-консоли MultiOTP.

Внешний вид веб-консоли MultiOTP со списком пользователей, синхронизированных из AD, представлен в Приложении А (А.1).

2.3.2 Процесс регистрации пользователя

Шаг 1. Генерация QR кода

Администратор в веб консоли выбирает пользователя и нажимает кнопку «Print». Система генерирует QR код (см. рисунок 2.11).

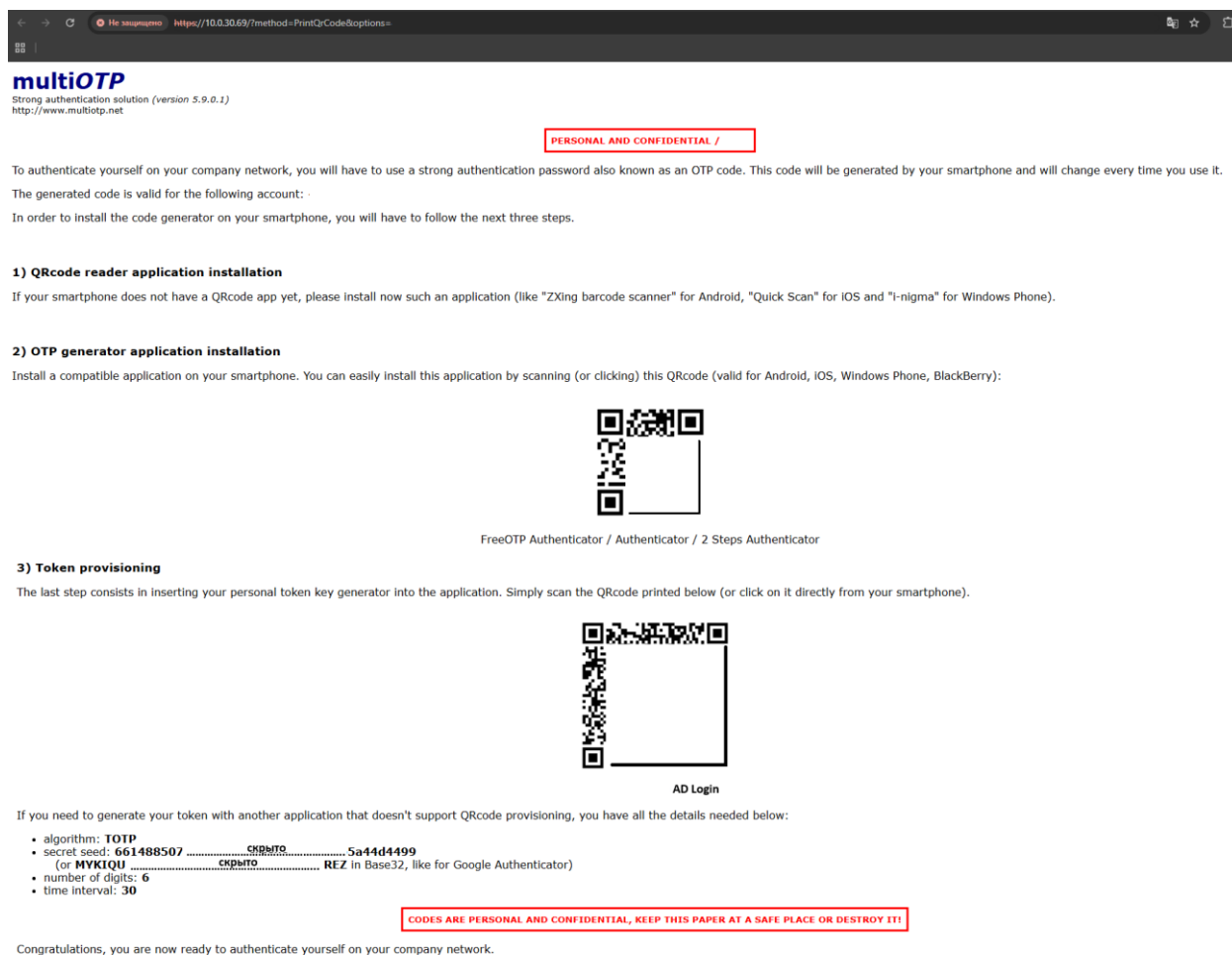


Рисунок 2.11 - QR код и секретный ключ пользователя

Шаг 2. Установка приложения аутентификатора

Пользователь устанавливает на смартфон приложение Google Authenticator версия 6.0 или выше или аналогичное TOTP совместимое приложение. Тестирование проводилось на следующих мобильных операционных системах:

- Android 4 и выше, Google Authenticator 6.0+
- iOS 16 и выше, Google Authenticator 4.0+

Шаг 3. Сканирование QR кода

Пользователь сканирует QR код через приложение. Приложение начинает генерировать 6 значные коды, обновляющиеся каждые 30 секунд.

Шаг 4. Проверка работоспособности

Администратор проверяет корректность привязки (см. рисунок 2.12):

```
C:\Program Files\MultiOTP>multiotp.exe --check-token user666 654321
MultiOTP - Open Source strong OTP solution version 5.9.0.1
Copyright (c) 2010-2024 SysCo systèmes de communication sa
Licensed under GNU LGPL

[TOTP] Loading token for user: user666
[TOTP] Secret key loaded from: C:\Program
Files\MultiOTP\users\user666.db
[TOTP] Current timestamp: 1749384720
[TOTP] Window: current (0), time step: 30s
[TOTP] Computed code: 654321
[TOTP] User entered: 654321
[TOTP] Token is VALID
Token is valid

C:\Program Files\MultiOTP>
```

Рисунок 2.12 - Проверка корректности привязки

Ожидаемый вывод: Token is valid.

2.3.3 Инструкция для пользователя

Для пользователей разработана краткая инструкция:

1. Установите приложение Google Authenticator из App Store или Google Play.
2. Зарегистрируйтесь - получите QR код у администратора и отсканируйте его.
3. Вход в систему:
 - Введите логин и пароль AD.
 - В следующем окне введите 6 значный код из приложения.
1. Резервные коды - обратитесь в тех.поддержку. Используйте при утере телефона.
2. Потеря телефона - немедленно сообщите администратору.

2.3.4 Процедура восстановления доступа при утере телефона

В случае утери или поломки мобильного устройства, на котором установлено приложение аутентификатор, пользователь не может выполнить вход в систему. Для восстановления доступа предусмотрена следующая процедура:

Шаг 1. Обращение пользователя. Пользователь обращается к администратору по телефону или электронной почте с заявкой на сброс 2FA.

Шаг 2. Идентификация пользователя. Администратор идентифицирует пользователя по корпоративной SIM карте или ответу на контрольный вопрос.

Шаг 3. Сброс токена. Администратор в веб консоли MultiOTP выбирает учетную запись пользователя и выполняет сброс токена, кнопка «Delete».

Шаг 4. Генерация нового QR кода. Администратор создает новый токен для пользователя, кнопка «Print», генерируя новый секретный ключ и QR код.

Шаг 5. Выдача резервного кода. Администратор распечатывает резервный код, кнопка «Scratchlist» и передает пользователю защищенным способом.

Внешний вид веб-консоли MultiOTP резервных кодов пользователя Приложении А (А.2).

Шаг 6. Повторная регистрация. Пользователь устанавливает приложение аутентификатор на новое устройство и сканирует QR код.

Шаг 7. Проверка. Пользователь выполняет тестовый вход для подтверждения работоспособности.

Все действия администратора фиксируются в журнале событий MultiOTP.

2.3.5 Выводы по разделу

В разделе 2.3 выполнены следующие работы:

1. Выполнена синхронизация пользователей из AD.
2. Настроен процесс регистрации мобильных устройств.
3. Составлена инструкция для пользователей.

2.4 Тестирование разработанного решения

2.4.1 Методика тестирования

Были определены следующие сценарии тестирования:

1. Успешная аутентификация, корректный пароль + верный TOTP
2. Неверный TOTP код
3. Неверный пароль
4. Истекший TOTP код
5. Блокировка при превышении лимита попыток

6. Оценка производительности

2.4.2 Результаты тестирования

Тест 1: Успешная аутентификация

Пользователь ввел корректный пароль AD и верный TOTP код.

Результат: Доступ разрешен.

Лог MultiOTP:

```
2026-05-04 09:15:32 - Credential Provider: login attempt for User666
2026-05-04 09:15:32 - LDAP: authentication OK for User666
2026-05-04 09:15:32 - TOTP: code 654321 is VALID for User666
2026-05-04 09:15:32 - Credential Provider: access GRANTED
```

Тест 2: Неверный TOTP код

Пользователь ввел корректный пароль, но неверный TOTP код.

Результат: Доступ запрещен.

Лог MultiOTP:

```
2026-05-04 09:17:45 - TOTP: code 111111 is INVALID for User666
2026-05-04 09:17:45 - Credential Provider: access DENIED
```

Тест 3: Неверный пароль

Пользователь ввел неверный пароль AD.

Результат: Доступ запрещен (проверка TOTP не выполнялась).

Лог MultiOTP:

```
2026-05-04 09:20:12 - LDAP: authentication FAILED for User666
2026-05-04 09:20:12 - Credential Provider: access DENIED
```

Тест 4: Истекший TOTP код

Пользователь ввел TOTP код, сгенерированный более 60 секунд назад.

Результат: Доступ запрещен.

Лог MultiOTP:

```
2026-05-04 11:35:22 - TOTP: code 123456 is EXPIRED for User666
```

Тест 5: Блокировка при превышении лимита попыток

Пользователь ввел неверный TOTP код 3 раза подряд (max_block_failures=3).

Результат: Блокировка на 15 минут = 900 секунд.

Лог MultiOTP:

```
2026-05-04 14:30:15 - TOTP: failure 3/3 for User666, account BLOCKED for 900 seconds
```

Тест 6: Производительность

Выполнено 10 замеров времени аутентификации (см. таблицу 2.6).

Таблица 2.6 - Сравнение времени аутентификации

Сценарий	Среднее время (сек)	Разница
Без 2FA	0.8	-
С 2FA	1.3	+0.5 сек

2.4.3 Сводная таблица результатов

Таблица 2.7 - Сводная таблица результатов

№	Тестовый сценарий	Ожидаемый результат	Фактический результат	Статус
1	Успешная аутентификация	Доступ разрешен	Доступ разрешен	Успех
2	Неверный TOTP код	Доступ запрещен	Доступ запрещен	Успех
3	Неверный пароль	Доступ запрещен	Доступ запрещен	Успех
4	Истекший TOTP код	Доступ запрещен	Доступ запрещен	Успех
5	Превышение лимита попыток 3 раза	Блокировка на 15 мин	Блокировка на 15 мин	Успех
6	Производительность	+0.5 сек	+0.5 сек	Успех

Результаты тестирования подтверждают:

- корректную работу двухфакторной аутентификации;
- эффективность механизмов безопасности, блокировка после 3 попыток;
- незначительное влияние на производительность, +0.5 секунды.

2.4.4 Оценка производительности и масштабируемости

В ходе тестирования была проведена оценка потребления ресурсов сервера MultiOTP при одновременной работе 15 пользователей, а также выполнен анализ масштабируемости решения для прогнозирования его работы при росте числа пользователей.

Конфигурация серверного оборудования

Для развертывания сервиса MultiOTP выделен отдельный сервер со следующими параметрами (см. таблицу 2.8):

Таблица 2.8 - Конфигурация сервера MultiOTP

Параметр	Значение
Операционная система	Windows Server 2019
Оперативная память (RAM)	2 ГБ
Дисковое пространство (HDD)	30 ГБ
Процессор	2 vCPU
Сетевое подключение	1 Гбит/с

Результаты измерения потребления ресурсов

Измерения проводились в три этапа, режим простоя - без активных сессий, штатная нагрузка - 15 пользователей, работающих в обычном режиме, пиковая нагрузка - 10 одновременных попыток аутентификации (см. таблицу 2.9).

Таблица 2.9 - Потребление ресурсов сервера MultiOTP

Параметр	Режим простоя	Штатная нагрузка - 15 пользователей	Пиковая нагрузка - 10 одновременных аутентификаций
Процессор (CPU), %	менее 1%	3-5%	12-18%
Оперативная память (RAM), МБ	~35 МБ	~50 МБ	~65 МБ
Дисковое пространство, секретные ключи, МБ	2 МБ	~5 МБ	~5 МБ
Дисковое пространство, логи, МБ в месяц	-	~10 МБ	~10 МБ
Сетевой трафик (LDAP-запросы) на 1 аутентификацию, КБ	-	~1-2 КБ	~1-2 КБ

Оценка масштабируемости

Исходя из полученных данных, выполнен прогноз потребления ресурсов при увеличении числа пользователей.

Таблица 2.10 - Прогноз потребления ресурсов в зависимости от числа пользователей (см. таблицу 2.10)

Число пользователей	Прогнозируемая нагрузка на CPU	Прогнозируемое потребление RAM	Примечание
15 - текущее	3-5%	~50 МБ	Штатный режим
50	5-8%	~70 МБ	Требуется мониторинг
100	8-12%	~100 МБ	Работоспособно
200	12-18%	~150 МБ	Предел для данной конфигурации
500+	>30%	~300 МБ	Рекомендуется увеличение RAM до 4 ГБ и выделение отдельного сервера

Анализ узких мест

Основным узким местом системы является не сам сервер MultiOTP, а контроллер домена, обрабатывающий LDAP запросы. Каждая аутентификация пользователя генерирует 1-2 LDAP-запроса к контроллеру домена. При штатной нагрузке, 15 пользователей, каждый выполняет 5-10 входов в день, контроллер домена успешно справляется с запросами без дополнительной нагрузки.

Обеспечение отказоустойчивости, резервный сервер

Для обеспечения высокой доступности сервиса 2FA предусмотрено развертывание резервного сервера MultiOTP со следующими параметрами (см таблицу 2.11):

Таблица 2.11 - Конфигурация резервного сервера MultiOTP

Параметр	Значение
Операционная система	Windows Server 2019
Оперативная память (RAM)	2 ГБ
Дисковое пространство (HDD)	30 ГБ
Процессор	2 vCPU
Режим работы	Горячий резерв

Механизм синхронизации и переключения

1. Синхронизация данных: Папка C:\Program Files\MultiOTP, содержащая конфигурацию и секретные ключи пользователей, синхронизируется с резервным сервером с помощью утилиты gobosoru каждые 5 минут.
Используемая команда (см. рисунок 2.13):

```

C:\Users\Administrator>robocopy ^
\\MULTIOTP01\C$\Program Files\MultiOTP ^
\\MULTIOTP02\C$\Program Files\MultiOTP ^
/MIR /R:3 /W:10

-----
ROBOCOPY      ::      Robust File Copy for Windows
-----

Started : Sunday, June 8, 2026 10:15:30 AM
Source  : \\MULTIOTP01\C$\Program Files\MultiOTP\
Dest    : \\MULTIOTP02\C$\Program Files\MultiOTP\

Files : *.*

Options : *.* /S /E /COPY:DAT /PURGE /MIR /R:3 /W:10

-----

New Dir      0      C:\Program Files\MultiOTP\
New File     168      multiotp.exe
New File     3452     multiotp.ini
New File     458      users\user666.db
New File     458      users\admin_domen.db
...

-----

Total      Copied      Skipped      Mismatch      FAILED
Extras
  Dirs :      12          2          10          0          0
0
  Files :      18         18          0          0          0
0
  Bytes :    5.23 m    5.23 m          0          0          0
0
  Times :    0:00:00    0:00:00          0          0          0
0:00:00

Speed :      149,000,000 Bytes/sec.
Speed :      8,527.000 MegaBytes/min.

Ended : Sunday, June 8, 2026 10:15:31 AM
C:\Users\Administrator>

```

Рисунок 2.13 - Синхронизация данных по средством Robocopy

2. Переключение при отказе: При недоступности основного сервера MultiOTP01 администратор выполняет ручное переключение на резервный сервер MultiOTP02 путем переназначения DNS имени или изменения настроек Credential Provider на сервере терминалов. Время восстановления сервиса (RTO) составляет не более 15 минут.
3. Мониторинг: Настроен мониторинг доступности сервера MultiOTP01 через систему оповещения (проверка порта 8080 каждые 60 секунд). При недоступности основного сервера администратор получает уведомление по электронной почте.

Вывод по разделу

Выделенная конфигурация сервера, 2 ГБ RAM, 30 ГБ HDD, Windows Server 2019, является достаточной для обслуживания текущего количества пользователей - 15+ и позволяет масштабировать систему до 200 пользователей без модернизации оборудования. Основным узким местом

является контроллер домена, обрабатывающий LDAP запросы. Для обеспечения отказоустойчивости настроен резервный сервер с синхронизацией данных каждые 5 минут, что позволяет восстановить работоспособность сервиса в течение 15 минут при отказе основного сервера.

Выводы по главе 2

Во второй главе выполнены следующие работы:

1. Проанализирована инфраструктура ИП Сокова Е.А. и сформулированы требования.
2. Спроектирована архитектура сервиса 2FA без использования RADIUS.
3. Выполнена установка MultiOTP версии 5.9.0.1, настройка службы и веб интерфейса.
4. Выполнена интеграция с AD через LDAP.
5. Установлен и настроен Credential Provider для RDP доступа.
6. Настроены резервные секретные ключи.
7. Проведено тестирование, подтвердившее работоспособность системы.

Разработанный сервис 2FA готов к эксплуатации в инфраструктуре ИП Сокова Е.А

ЗАКЛЮЧЕНИЕ

Целью данной дипломной работы являлась разработка и внедрение сервиса 2FA для доменной инфраструктуры на базе AD с использованием программного комплекса MultiOTP, обеспечивающего повышение уровня информационной безопасности организации.

В ходе выполнения работы были решены все поставленные задачи.

Результаты теоретической главы

В первой главе был проведен теоретический анализ проблемы защиты доменной инфраструктуры.

1. Анализ доменной инфраструктуры как объекта защиты показал, что AD является критическим активом организации. Компрометация контроллера домена или учетной записи администратора может привести к полной потере контроля над всей IT инфраструктурой. В ходе анализа инфраструктуры ИП Сокова Е.А. выявлено, что все пользователи 15+ человек подключаются к рабочей среде через RDP к серверу терминалов TS.domen.lc.
2. Анализ актуальных угроз для доменной среды выявил основные риски: атаки Pass the Hash, фишинг, перебор паролей, кейлоггеры и атаки на протокол Kerberos Golden Ticket, Silver Ticket. Обосновано, что данные угрозы не могут быть устранены только за счет усиления парольной политики.
3. Изучены теоретические основы двухфакторной аутентификации. Показано, что комбинация факторов «знание» пароль и «владение» TOTP код способна блокировать более 99,9% атак на учетные записи. Протокол TOTP (RFC 6238) признан оптимальным для внедрения благодаря его открытости, независимости от сотовой связи, нулевой стоимости и возможности работы в офлайн режиме.

4. Проведен сравнительный анализ существующих решений для 2FA такие как Duo Security, Microsoft Windows Hello for Business, privacyIDEA, российские решения. На основе критериев интеграция с AD, поддержка TOTP, наличие Credential Provider, стоимость, открытость кода, возможность локального развертывания, обоснован выбор программного комплекса MultiOTP как оптимального для внедрения в условиях ИП Сокова Е.А.

Результаты практической главы

Во второй главе была представлена практическая реализация сервиса 2FA с учетом особенностей инфраструктуры, RDP-доступ, двухэтапный ввод пароля и TOTP кода.

1. Спроектирована архитектура сервиса 2FA на базе MultiOTP, включающая:
 - сервер терминалов TS.domen.lc с MultiOTP Service, Credential Provider и локальным хранением секретных ключей в папке C:\Program Files\MultiOTP\users\;
 - контроллер домена PDC01.domen.lc для проверки паролей через LDAP;
 - мобильные устройства пользователей с приложением Google Authenticator для генерации TOTP кодов;
 - веб интерфейс для централизованного администрирования.

Ключевая особенность архитектуры: Credential Provider установлен только на сервере терминалов, что позволяет пользователям подключаться с любых устройств без установки дополнительного ПО.

2. Выполнена установка и настройка MultiOTP версии 5.9.0.1:
 - установлена служба MultiOTP и веб-интерфейс на встроенном веб-сервере mongoose;

- выполнен файл конфигурации multiothp.ini с параметрами: max_block_failures=3, allow_password_only=0;
 - настроена интеграция с AD через LDAP с использованием служебной учетной записи svc_multiothp.
3. Выполнена синхронизация пользователей из AD командой multiothp.exe --ldap-users-sync. Все пользователи автоматически добавлены в локальное хранилище MultiOTR.
 4. Настроен Credential Provider для двухэтапного входа: сначала пользователь вводит логин и пароль AD, затем в отдельном окне - TOTP код из приложения Google Authenticator.
 5. Проведено тестирование разработанного решения по шести сценариям:
 - успешная аутентификация - доступ разрешен;
 - неверный TOTP код - доступ запрещен;
 - неверный пароль - доступ запрещен;
 - истекший TOTP код - доступ запрещен;
 - превышение лимита попыток 3 раза - блокировка на 15 минут;
 - оценка производительности - увеличение времени входа на 0,5 секунды.

Все тесты пройдены успешно.

Достижение цели и решение задач

Таким образом, цель дипломной работы достигнута. Разработан и внедрен сервис 2FA для доменной инфраструктуры на базе AD с использованием программного комплекса MultiOTR.

Все задачи, поставленные во введении, решены (см. таблицу 2.12).

Таблица 2.12 - Задачи дипломной работы

Задача	Результат
Анализ доменной инфраструктуры как объекта защиты	Выполнен в разделе 1.1
Анализ угроз информационной безопасности для доменной среды	Выполнен в разделе 1.2
Изучение теоретических основ 2FA и протокола TOTP	Выполнено в разделе 1.3
Сравнительный анализ решений 2FA и обоснование выбора MultiOTP	Выполнен в разделе 1.4
Проектирование архитектуры сервиса 2FA	Выполнено в разделе 2.1
Реализация серверной части, установка, настройка, интеграция с AD	Выполнено в разделе 2.2
Настройка клиентской части и регистрация пользователей	Выполнено в разделе 2.3
Тестирование разработанного решения	Выполнено в разделе 2.4

Практическая значимость

Практическая значимость работы заключается в следующем:

1. Разработанный сервис 2FA внедрен в реальную доменную инфраструктуру ИП Сокова Е.А. и используется 15+ сотрудниками.
2. Выбранное решение MultiOTP является открытым и бесплатным, что позволяет тиражировать опыт внедрения в других организациях с ограниченным бюджетом для образовательные учреждения, малый бизнес.
3. В работе представлены:
 - файл конфигурации `multiotp.ini` с оптимальными параметрами безопасности;

- инструкция для пользователей по работе с двухфакторной аутентификацией.
- 4. Двухэтапный процесс входа, сначала пароль AD, затем TOTP код, является интуитивно понятным для пользователей и не требует специального обучения.
- 5. Отсутствие необходимости установки Credential Provider на клиентские устройства и использования RADIUS сервера упрощает инфраструктуру и снижает затраты на внедрение.

Перспективы развития системы

Возможные направления дальнейшего развития системы:

- внедрение аппаратных токенов, YubiKey, Feitian для административных учетных записей;
- интеграция с другими сервисами организации, VPN-шлюз, почтовый сервер;
- миграция на импортозамещенные решения при появлении соответствующих требований;
- настройка автоматического уведомления администратора о блокировках пользователей.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

Нормативные и технические документы

1. RFC 6238. TOTP: Time Based One Time Password Algorithm / D. M'Raihi, S. Machani, M. Pei, J. Rydell. - Internet Engineering Task Force (IETF), 2011. - 16 p. - URL: <https://tools.ietf.org/html/rfc6238> (дата обращения: 27.05.2026). - Текст : электронный.
2. RFC 4226. HOTP: An HMAC-Based One-Time Password Algorithm / D. M'Raihi, M. Bellare, F. Hoornaert [et al.]. - Internet Engineering Task Force (IETF), 2005. - 34 p. - URL: <https://tools.ietf.org/html/rfc4226> (дата обращения: 27.05.2026). - Текст : электронный.

Учебники и учебные пособия

3. Баринов, С. А. Информационная безопасность : учебное пособие для СПО / С. А. Баринов. - 3-е изд., стер. - Саратов : Профобразование, 2024. - 195 с. - ISBN 978-5-4488-2024-3. - Текст : непосредственный.
4. Галатенко, В. А. Основы информационной безопасности : учебное пособие / В. А. Галатенко. - 5-е изд., перераб. и доп. - Москва : Интернет-Университет Информационных Технологий, 2024. - 384 с. - ISBN 978-5-4497-0244-9. - Текст : непосредственный.
5. Кузин, А. В. Информационная безопасность : учебник для СПО / А. В. Кузин. - 2-е изд., перераб. и доп. - Москва : Юрайт, 2025. - 285 с. - (Профессиональное образование). - ISBN 978-5-534-19678-8. - Текст : непосредственный.
6. Маврин, С. В. Информационная безопасность и защита информации : учебное пособие / С. В. Маврин. - Ростов-на-Дону : Феникс, 2024. - 312 с. - (Среднее профессиональное образование). - ISBN 978-2-222-41578-0. - Текст : непосредственный.

7. Партыка, Т. Л. Информационная безопасность : учебное пособие / Т. Л. Партыка, И. И. Попов. - 6-е изд., перераб. и доп. - Москва : Форум : ИНФРА-М, 2024. - 430 с. - ISBN 978-5-8199-0978-0. - Текст : непосредственный.
8. Щеглов, А. Ю. Защита информации в информационных системах : учебник для СПО / А. Ю. Щеглов. - 2-е изд., стер. - Москва : Юрайт, 2024. - 293 с. - ISBN 978-5-534-19989-5. - Текст : непосредственный.

Техническая документация и статьи

9. Интеграция MultiOTP с AD : техническая документация [Электронный ресурс] // GitHub. - URL: <https://github.com/multiOTP/multiotp> (дата обращения: 27.05.2026). - Текст : электронный.
10. Настройка 2FA в Windows с помощью MultiOTP : официальное руководство / SysCo systèmes de communication sa. - 2024. - 45 р. - URL: <https://github.com/multiOTP/multiotp/wiki> (дата обращения: 27.05.2026). - Текст : электронный.
11. Настройка многофакторной аутентификации в Microsoft Entra ID : документация [Электронный ресурс] / Microsoft Corporation. - 2025. - URL: <https://learn.microsoft.com/ru-ru/entra/identity/authentication/> (дата обращения: 27.05.2026). - Текст : электронный.
12. Баранова, Е. К. Анализ методов 2FA в корпоративных сетях / Е. К. Баранова, А. В. Смирнов. - Текст : непосредственный // Информационные технологии и системы. - 2024. - № 2 (48). - С. 45-52.
13. Козлов, В. В. Сравнительный анализ решений многофакторной аутентификации для малого бизнеса / В. В. Козлов. - Текст : непосредственный // Информационная безопасность регионов. - 2024. - Т. 20, № 3. - С. 112-118.

14. Михайлов, Д. А. Протокол TOTP: принципы работы и особенности реализации / Д. А. Михайлов. - Текст : непосредственный // Вестник информационных технологий. - 2023. - № 4 (42). - С. 23-30.
15. Новиков, П. С. Актуальные угрозы безопасности доменных инфраструктур / П. С. Новиков, Е. В. Морозова. - Текст : непосредственный // Системы управления и информационные технологии. - 2024. - № 1 (55). - С. 67-73.

Интернет-ресурсы

16. Duo Security : официальный сайт [Электронный ресурс]. - URL: <https://duo.com> (дата обращения: 27.05.2026). - Текст : электронный.
17. Google Authenticator : официальная страница приложения [Электронный ресурс]. - URL: <https://support.google.com/accounts/answer/1066447> (дата обращения: 27.05.2026). - Текст : электронный.
18. Microsoft Authenticator : официальная документация [Электронный ресурс]. - URL: <https://www.microsoft.com/ru-ru/security/mobile-authenticator-app> (дата обращения: 27.05.2026). - Текст : электронный.
19. MultiOTP : официальный репозиторий / SysCo systèmes de communication sa [Электронный ресурс]. - GitHub. - URL: <https://github.com/multiOTP/multiotp> (дата обращения: 27.05.2026). - Текст : электронный.
20. privacyIDEA : официальный сайт / NetKnights GmbH [Электронный ресурс]. - URL: <https://www.privacyidea.org> (дата обращения: 27.05.2026). - Текст : электронный.
21. Статистика инцидентов информационной безопасности за 2024-2025 годы [Электронный ресурс] // Positive Technologies. - URL: <https://www.ptsecurity.com/ru-ru/research/analytics/> (дата обращения: 27.05.2026). - Текст : электронный.

Приложения А

А.1 - Репозиторий проекта



Ссылка для ручного ввода

https://github.com/Demiantron/Diplom_multiotp

А.2 Веб интерфейс администрирования MultiOTP

На рисунке А.1 представлена веб консоль MultiOTP со списком пользователей системы.

multiOTP web administration console
the open source strong authentication library
multiOTP 5.9.0.1 2022-05-19
Web service is ready 2026-05-29 10:22:02, nginx/1.18.0, PHP/7.4.28

Logout

[+] Change admin password
[+] Import new hardware tokens
[+] List of hardware token
[-] Add a new user

Username:
Email address:
Mobile phone (SMS):
With prefix PIN: ☐ yes ☒ no
Specific prefix PIN:
Select a token: software ▼
Token type: TOTP ▼
Add this user

[+] Resync a user
[+] Check a user
[+] Backup the configuration
[+] Restore the configuration

List of users (11 users)

Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]
Delete	Print	Scratchlist	Resync	› [AD/LDAP]

Рисунок А.1 - Веб консоль MultiOTP со списком пользователей системы

На рисунке А.2 представлены резервные коды пользователя в веб консоли MultiOTP.

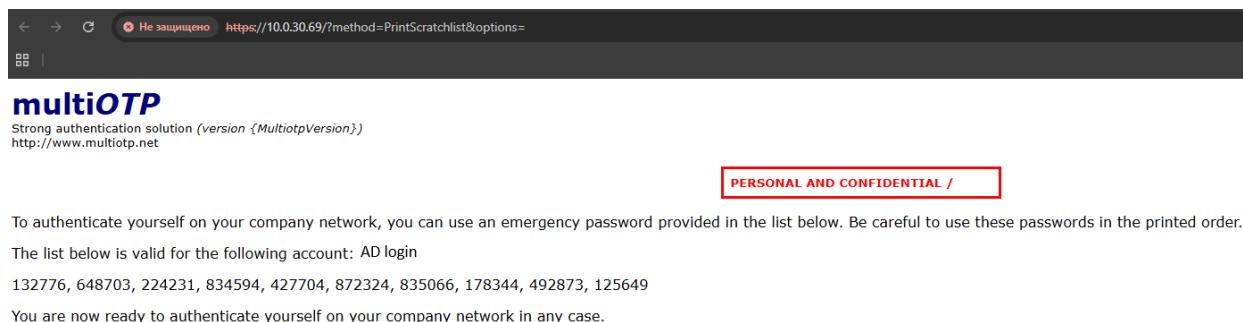


Рисунок А.2 - Резервные коды пользователя в веб консоли MultiOTP

А.3 Файл конфигурации multiotp.ini

Листинг А.3 Файл конфигурации multiotp.ini

```
multiotp-database-format-v3
encryption_hash=378054AD.....0F036127153DC
server_secret:=WEhGWn.....mZX1eR1Iy
actual_version=
admin_password_hash:=
anonymous_stat=1
anonymous_stat_last_update=1589240438
anonymous_stat_random_id=d11fb6d92be5c2e329a3b86722c05d4c4da5e4e1
// Основные настройки
auto_resync=1
backend_type=files
case_sensitive_users=0
debug=0
default_algorithm=totp
demo_mode=0
developer_mode=0
log=1
max_block_failures=3
max_delayed_failures=3
// ldap
ldap_activated=1
ldap_account_suffix=@local.local
ldap_base_dn=DC=local,DC=local
ldap_bind_dn=CN=svc_multiotp,CN=Users,DC=local
ldap_bind_password:=
ldap_cn_identifier=sAMAccountName
ldap_domain_controllers=dc01.local
ldap_group_attribute=memberOf
ldap_group_cn_identifier=cn
ldap_network_timeout=10
ldap_port=389
```

```
ldap_recursive_groups=1
ldap_server_type=1
ldap_ssl=0
ldap_time_limit=30
// Локальное хранение ключей
hash_salt_full_path=
encryption_key_full_path=
cache_data=0
cache_ldap_hash=1
// Параметры TOTP
token_otp_list_of_length=6
default_algorithm=totp
max_time_window=600
max_event_window=100
timezone=Europe/Zurich
// Веб интерфейс
issuer=multiOTP
language=en
self_registration=1
// Резервные коды
scratch_passwords_digits=6
scratch_passwords_amount=10
// Credential provider
[credentialprovider]
enabled=1
prompt_format=Password + 6-digit code
allow_password_only=0
```

(Конец Приложения А)